

Hardening Email Sender Authentication: Reproducing SPF/DKIM/DMARC Misconfiguration Attacks

Guilherme Ferreira
up201706719@fe.up.pt

João Oliveira
up202205302@fe.up.pt

Ayrton da Cruz
up202300120@fe.up.pt

Ana Lúcia Ferreira
up202105838@fe.up.pt

Abstract

This project addresses sender spoofing enabled by misconfigured SPF, DKIM, and DMARC records—a concrete instance of OWASP A02:2025 Security Misconfiguration and A07:2025 Authentication Failures [0], [0]. Despite widespread deployment of these standards, weak or inconsistent policies continue to expose organizations to phishing and impersonation. We build a controlled lab with test domains and mail servers (Postfix/Dovecot) deliberately misconfigured, reproduce documented spoofing attacks using swaks, Espoofer [0], and custom Python scripts, and collect network captures to characterize how policy variations affect authentication results. Based on these experiments, we propose DNS- and MTA-level hardening guidelines, delivering a proof-of-concept lab that demonstrates both successful spoofing under realistic misconfigurations and the effectiveness of the proposed defenses.

I. Introduction

Email remains a primary vector for phishing attacks, with many campaigns succeeding by forging messages from trusted domains. SPF, DKIM, and DMARC were designed to prevent this, but weak or inconsistent deployments still allow impersonation [0], [0]. We target this gap by reproducing misconfigurations in a lab, demonstrating exploitability, and evaluating practical defenses at the DNS and MTA levels.

II. Related Work

Chen et al. identify 18 practical evasion techniques arising from composition inconsistencies across SPF, DKIM, and DMARC deployments [0], motivating our focus on misconfiguration over cryptographic weaknesses. Espoofer systematizes many such attacks into a reusable testing tool [0]. Roobal et al. further show that rule-based mechanisms are insufficient against sophisticated spoofing, and that timestamp anomalies in email headers provide a meaningful detection signal [0]. We frame our work under OWASP A02:2025 and A07:2025 [0], [0], as misconfigured sender-authentication records are a concrete instance of these vulnerability classes.

References

- [1] OWASP Foundation, “A02:2025 – security misconfiguration,” https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/, 2025, accessed: 2026-03-16.
- [2] —, “A07:2025 – authentication failures,” https://owasp.org/Top10/2025/A07_2025-Authentication_Failures/, 2025, accessed: 2026-03-16.
- [3] J. Chen, “Espoofer: An email spoofing testing tool,” <https://github.com/chenjj/espoofer>, accessed: 2026-03-16.
- [4] Infraforge, “Spf, dkim, dmarc: Common setup mistakes,” <https://www.infraforge.ai/blog/spf-dkim-dmarc-common-setup-mistakes>, 2026, accessed: 2026-03-16.
- [5] DMARCLY, “How to implement dmarc/dkim/spf to stop email spoofing/phishing: The definitive guide,” <https://dmarcly.com/blog/how-to-implement-dmarc-dkim-spf-to-stop-email-spoofing-phishing-the-definitive-guide>, 2024, accessed: 2026-03-16.
- [6] J. Chen, V. Paxson, and J. Jiang, “Composition kills: A case study of email sender authentication,” in Proceedings of the 29th USENIX Security Symposium (USENIX Security 2020), 2020, pp. 2183–2199. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity20/presentation/chen-jianjun>
- [7] Roobal, R. Saxena, and V. Dillu, “Real-time email spoofing detection using machine learning and timestamp anomaly analysis,” <https://jatit.org/volumes/Vol103No23/28Vol103No23.pdf>, 2025, accessed: 2026-03-18.